The 2004 UCSB Capture The Flag Exercise

Giovanni Vigna
Reliable Software Group
Department of Computer Science, UCSB
http://www.cs.ucsb.edu/~vigna

Previous Exercises

- Red Team/Blue Team
  - Two teams
    - Red Team: has to obtain a "flag" file hidden on specific hosts
    - Blue Team: has to protect the flag and detect attacks
- Capture The Flag
  - Two teams
    - Alpha Team
    - Omega Team
  - Defend flag and capture other team's flag
- Treasure Hunt
  - Two teams
    - Alpha Team
    - Omega Team
  - Race side-by-side through an attack scenario
- Nation-wide Capture The Flag
  - 14 teams from 7 colleges in the USA

The International CTF

- A "Capture The Flag" hacking contest
- Teams from a number of Universities/Institutions from the US and Europe compete against each other
- Each team is given the copy of a server (prepared by the organizers) containing undisclosed vulnerabilities
- Each team has to defend the server it manages and attack the servers managed by other teams
- The teams have 4 hours to set up their protections and compromise the other teams' computers
- A real-time scoring system determines who is the best at defense and attack

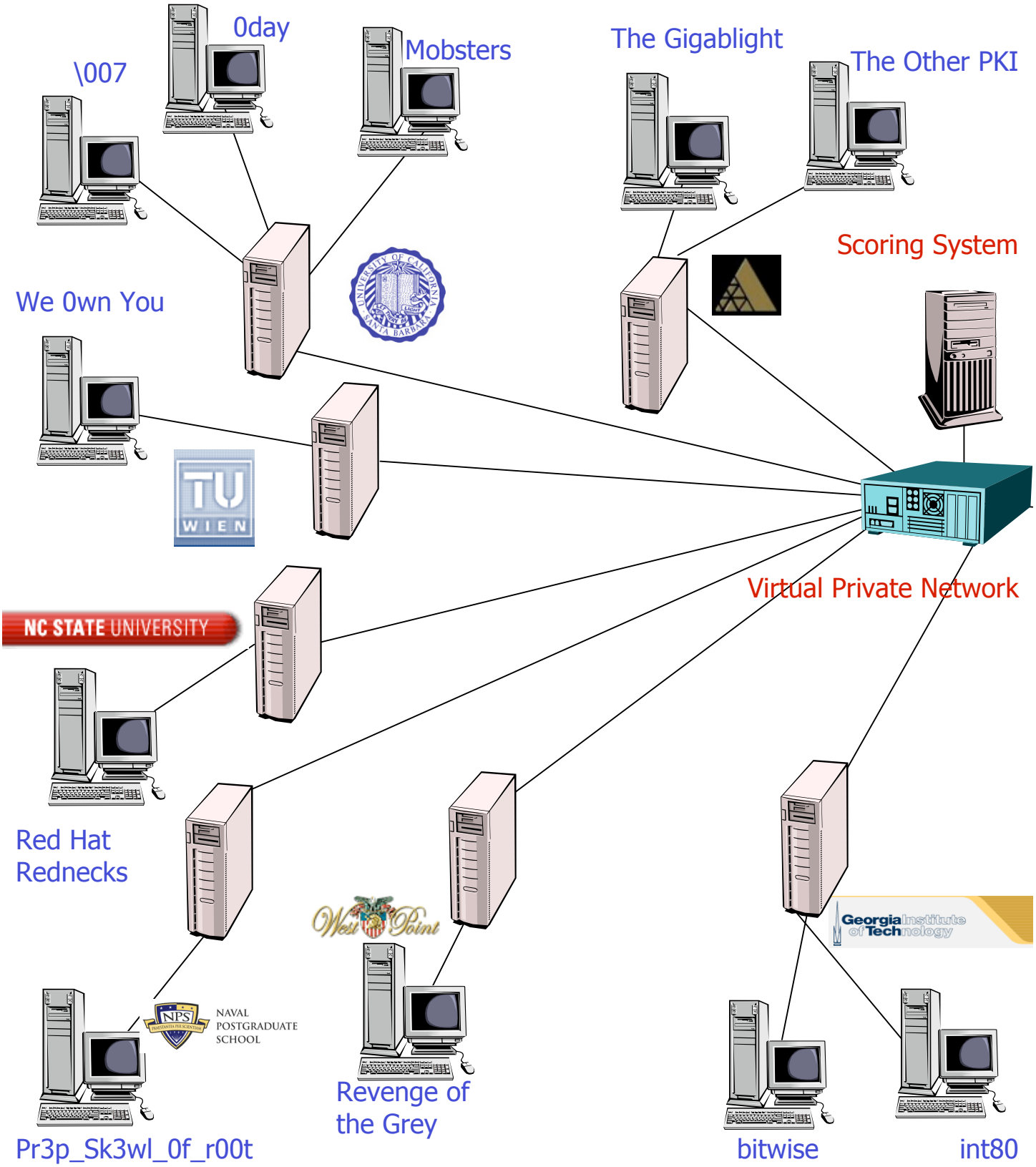
Why Is This A Big Deal?

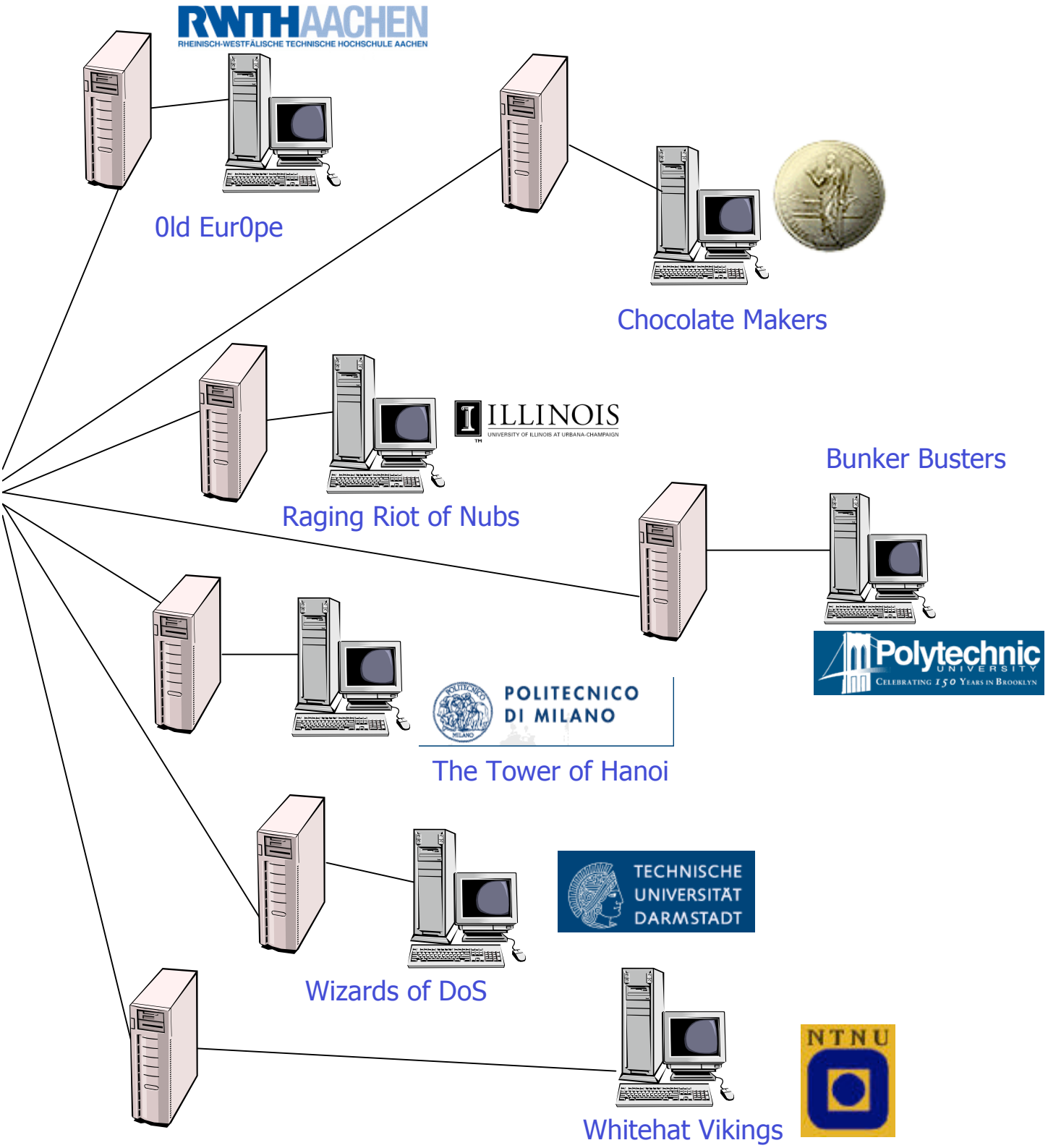
- This is the first time that something like this is attempted!
- Other competitions were either
  - Local (e.g., DEFCON in Las Vegas)
  - Limited in the number of teams (e.g., max 3-4)
  - Limited in the geographic spread (e.g., US-only)
- This contest involves graduate and undergraduate students, it is completely "open", and it has a rigorous scoring system
- This competition includes teams from Universities and Institutions spread across Europe and the USA
- Team size is approx 12 students
- 18 Teams from 14 Universities in 5 countries 5 time zones
- Total number of students involved: ~200

Teams and Sites

- UC Santa Barbara, USA
  - 007, 0day, Mobsters
- Technical University of Vienna, Austria
  - We 0wn You
- United States Military Academy, USA
  - Revenge of the Grey
- Georgia Tech, USA
  - bitwise, int80
- New York Polytechnic University, USA
  - Bunker Busters
- North Carolina State University, USA
  - Red Hat Rednecks
- Naval Postgraduate School of Monterey, USA
  - Pr3p_Sk3wl_0f_r00t
- Politecnico di Milano, Italy
  - The Tower of Hanoi
- University of Illinois, Urbana-Champaign, USA
  - Raging Riot of Nubs
- Darmstadt University of Technology, Germany
  - Wizards of DoS
- Norwegian University of Science and Technology, Norway
  - Whitehat Vikings
- Universita' degli studi di Milano, Italy
  - Chocolate Makers
- RWTH Aachen University, Germany
  - 0ld Eur0pe
- University of Nebraska, Omaha
  - The Gigablight, The Other PKI

How Does This Work?




RWTH AACHEN
RHEINISCH-WESTFÄLISCHE TECHNISCHE HOCHSCHULE AACHEN
0ld Eur0pe
Chocolate Makers
ILLINOIS
UNIVERSITY OF ILLINOIS AT URBANA-CHAMPAIGN
Raging Riot of Nubs
Bunker Busters
Polytechnic
UNIVERSITY
CELEBRATING 150 YEARS IN BROOKLYN
POLITECNICO
DI MILANO
The Tower of Hanoi
TECHNISCHE
UNIVERSITÄT
DARMSTADT
Wizards of DoS
NTNU
Whitehat Vikings

Teams' Hosts

- OS image configured with a number of services running on VMWare
  - Debian on VMWare 4.5.2 on Fedora Core 2
- Service examples
  - World-Wide Web, FTP, Audio streaming, Custom services
- Services have a number of exploitable vulnerabilities
- OS images are distributed at the beginning of the day
- Source code for some services is distributed at the beginning of the actual contest

Flags

- The scoring systems simulates one or more users that connect to the server and use the services
- As a side-effect of using the services, some flags are set (e.g., by leaving a message in a password-protected discussion forum)
- The flags are accessible (in theory) only to a correctly authenticated user (with credentials that are different for each team!)
- To capture another team's flag one has to:
  - Access the flag of a service in another team's server
  - Submit the flag to the scoring system

Monitoring/Scoring

- Each service is equipped with
  - A "get flag" method
  - A "set flag" method
- Getting and setting the flags do not involve exploiting a vulnerability
- A service can be in different states
  - Dead
  - Running
  - Functional (running and flags can be retrieved and set)

Monitoring/Scoring

- The scoring systems attempts to read the flag
  - If no connection can be established the service is considered down
    - No points are assigned
  - If the flags are not accessible the service is considered non-functional
    - No points are assigned
- The scoring systems attempts to write the flag
  - If no connection can be established the service is considered down
    - No points are assigned
  - If the flags are not writable the service is considered non-functional
    - No points are assigned

Analyzing The Flag

- If the flag is different from the last flag value set by the scoring system, something wrong happened
  - The flag is ignored
  - A new flag is set
  - The team receives no points
- If the flag is identical to the last flag value set
  - If no other team have submitted the flag value to the scoring system, the team is assigned a number of defense points
  - If one or more other teams have submitted that flag, then the other teams receive a number of attack points
  - The attack points are proportional to the percentage of services currently provided by the attacker (this is to prevent "attack-only" behavior)

Example

- Server implements a web-based discussion service where authenticated users can post messages
- Users can post messages publicly or to a private discussion forum that requires a username and a password to access the forum contents
- The scoring system connects to the service of team B and creates a new forum, called "recipes" protected by a password, say "spaghetti”
- Then it generates the flag and creates a message in the forum that contains the flag (e.g., in the body of a posting to that forum)
- A sample flag:
  `MTNzEwECA+hWjCb8t8/FgbEg/mSm1hbU231kjg==`

Example

- After some time, the scoring system attempts to log into the forum (using forum name “recipes” and password “spaghetti”) and checks if the flag is still there
- If it is, then a new flag is created as the body of another posting
  - Note that the scoring system might also decide to create a complete different forum to store the new flag
- In order to steal the flag, team A has to connect to team B's server and in some way access the contents of the “recipes” forum

Example

- Of course team A does not know the password used to create the forum and therefore it has to find some way to bypass security
- If successful team A will be able to read the flag
- Then, team A will immediately submit the flag using a form on the scoring web site
- The fact that team A stole the flag will be recorded and, at the end of the scoring period, some points will be granted to team A

Scoring Panel

- The scoring panel provides a snapshot of the status of the CTF
- It is accessible through a web page (refreshed every 30 seconds)
- It provides information of team's ping connectivity (ability to answer to ping probes)
- It provides information about the status of services
  - Down
  - Running but non-functional
  - Functional
  - Note: It does not provide information about the ownership of a service

Scoring Panel

- It provides information about the performance of a team in the last scoring period (say, last 10 minutes)
- Note: It does not provide absolute score values
- Penalties are assigned because of improper behavior (e.g., DOS attacks)
- Penalties are assigned because of traffic usage
- The final winner will be declared only at the end of the exercise

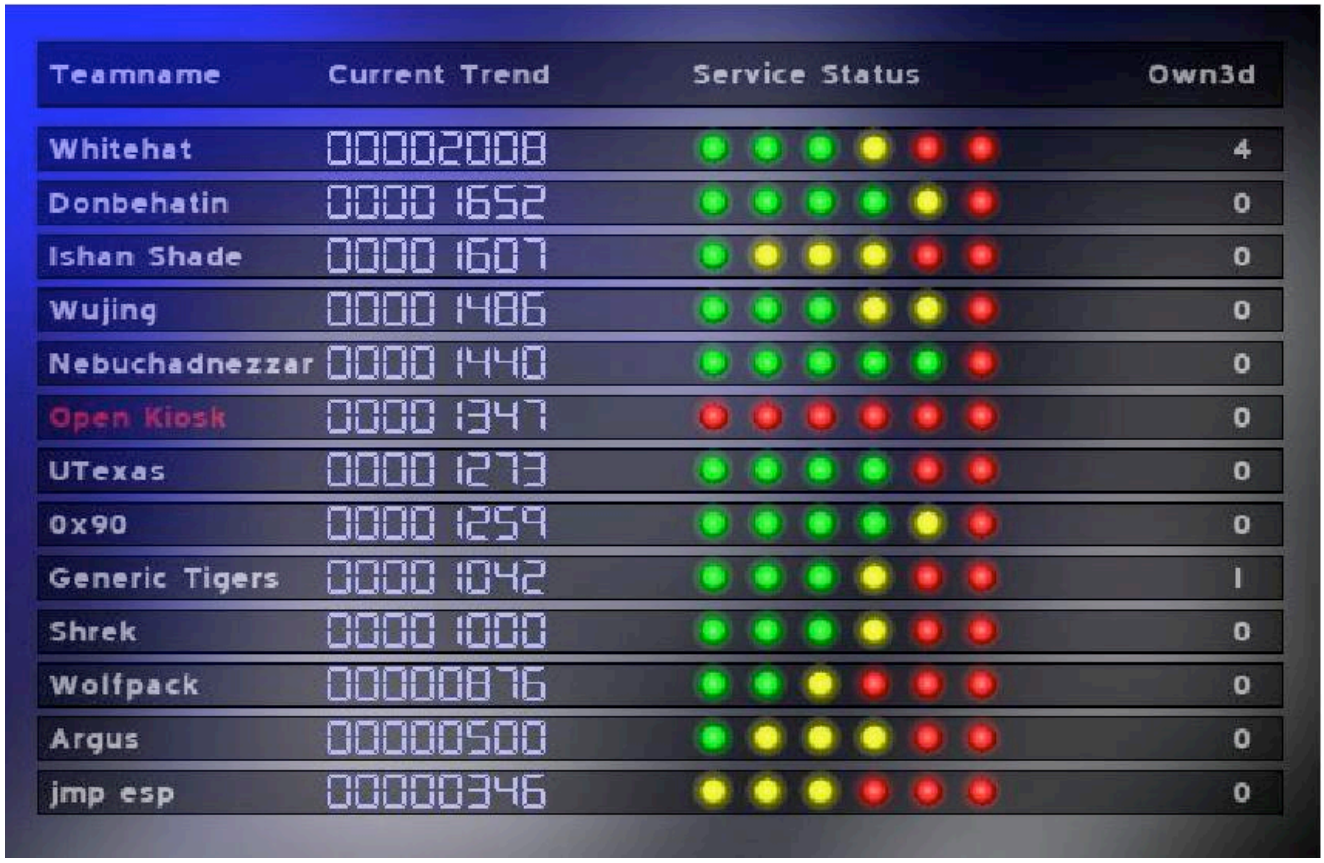
Attack Techniques

- Buffer overflow attacks
- Format string attacks
- Shell attacks
- Race condition attacks
- Misconfigurations
- Authentication attacks
- SQL Injection attacks
- Web-based attacks
  - Directory traversal
  - Cookie-based services
  - Cross-site scripting
  - Server-side applications
    - Lack of parameter validation

Skills

- Scanning
- Firewalling
- Vulnerability analysis
- For each type of vulnerability
  - How to identify a vulnerability
  - How to exploit a vulnerability
  - How to patch a vulnerability (without disrupting the get/set flag methods)
  - How to detect a vulnerability
- For each service
  - How to monitor the requests to a service
  - How to monitor the execution of a request
  - Protocol security analysis
  - Application security analysis

Scoreboard



Teamname	Current Trend	Service Status	Own3d
Whitehat	00002008		4
Donbehatin	0000 1652		0
Ishan Shade	0000 1607		0
Wujing	0000 1486		0
Nebuchadnezzar	0000 1440		0
Open Kiosk	0000 1347		0
UTexas	0000 1273		0
0x90	0000 1259		0
Generic Tigers	0000 1042		1
Shrek	0000 1000		0
Wolfpack	00000876		0
Argus	00000500		0
jmp esp	00000346		0